PRACTITIONER GUIDE

ISO 42001 + NIST AI RMF

The Practitioner Mapping Guide

How to implement both frameworks without duplicating effort

GRC Practitioners • CISOs • Risk Leads • Executives • Consultants

Contents

01	**Why Two Frameworks** The case for using ISO 42001 and NIST AI RMF together	1
02	**Framework Snapshots** What each framework covers and how it is structured	4
03	**Structural Comparison** How the two architectures align and where they diverge	6
04	**Master Mapping Table** Tier1: ISO 42001 clause-level mapping to NIST AI RMF	8
04B	**Annex A Control Mapping** Tier2: ISO 42001 Annex A controls mapped to NIST AI RMF	11
05	**Reading the Interconnectivity** What each NIST function contributes to ISO 42001	14
06	**Implementation Playbook** How to sequence both frameworks without duplicating effort	16
07	**The Gap Register** What each framework leaves open that the other fills	18
08	**Quick Reference Card** Key terms, relationships, and decision guide	20

Page references reflect the interior guide. Add 1 for the combined file including cover.

SECTION 01

Why Two Frameworks

The case for using ISO 42001 and NIST AI RMF together

Most organisations approaching AI governance pick one framework and work through it. That approach has a structural flaw. No single framework gives you everything you need.

ISO 42001 gives you a management system. It tells you what to build, what to document, who must own it, and how an external auditor will verify it. It ends with a certificate and a defensible evidence base. What it does not give you is a method for identifying and measuring the specific AI risks your organisation actually faces in its operational context.

NIST AI RMF gives you that method. Its four functions, Govern, Map, Measure, Manage, are a structured way to think about AI risk across the entire lifecycle of an AI system. It is practical, iterative, and context-sensitive. What it does not give you is a certifiable management system with auditable requirements and documented accountability.

> ***ISO 42001 establishes the formal policies and roles. NIST AI RMF provides the practical, risk-based steps to identify and measure harms in your specific operational context. Sequencing both creates a system that is certifiable and resilient.***

What This Guide Does

This guide maps every ISO 42001 clause to the corresponding NIST AI RMF function and subcategory. It shows the direction of each relationship: whether the frameworks are equivalent, complementary, or whether one leaves a gap the other fills. It then provides an implementation sequence for using both together without duplicating effort.

ISO 42001 answers:	NIST AI RMF answers:
• Have we built a management system for AI? • Are roles and responsibilities formally assigned? • Do our policies meet the standard requirements? • Can we demonstrate this to an external auditor? • Are we certification-ready?	• What AI risks exist in our specific context? • How do we categorise and prioritise those risks? • How do we measure harm likelihood and impact? • Are our controls actually working? • How do we respond when something changes?

Who This Guide Is For

Audience	How to use this guide
GRC Practitioners	Use the mapping tables as your primary implementation reference. The Annex A mapping in Section 04B is your audit preparation tool.
CISOs and AI Risk Leads	Use Section 05 to understand where NIST risk identification feeds directly into ISO management system requirements.
Executives and Board Members	Sections 01, 02, and 08 give you the strategic picture. Certifiable without NIST is incomplete. Resilient without ISO is unverifiable.
Consultants	Use the Gap Register in Section 07 as your gap assessment starting point with any client navigating both frameworks.

> ***This guide is designed to be used actively, not read once and filed. The mapping tables in Sections 04 and 04B are your working reference during implementation. The Gap Register in Section 07 is your starting point for any assessment engagement. The Implementation Playbook in Section 06 is your sequencing guide from day one.***

SECTION 02

Framework Snapshots

What each framework is, what it requires, and why it exists

ISO/IEC 42001:2023

Attribute	Detail
Full title	ISO/IEC 42001:2023 Information technology: Artificial intelligence: Management system
Published by	International Organisation for Standardisation (ISO) and International Electrotechnical Commission (IEC)
Published	December 2023
Type	Management system standard. Annex SL structure, same family as ISO 27001 and ISO 9001.
Certification	Yes. Third-party certification available through accredited certification bodies.
Applicability	Any organisation that develops, provides, or uses AI systems. Sector and size agnostic.
Core structure	Clauses 4 to 10 define the management system. Annex A provides 38 controls across 9 domains.
Primary output	A certified, auditable AI management system with documented policies, roles, objectives, and controls.
What it does NOT provide	A prescriptive method for identifying or measuring specific AI risks in your operational context.

NIST AI Risk Management Framework (AI RMF 1.0)

Attribute	Detail
Full title	Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Published by	National Institute of Standards and Technology (NIST), United States Department of Commerce
Published	January 2023
Type	Voluntary framework. Guidance-based, not a standard. No certification pathway.
Certification	No. Alignment is self-declared or assessed. No third-party certification body.
Applicability	Designed for US federal agencies and any organisation building or deploying AI. Widely adopted internationally.
Core structure	Four functions: GOVERN, MAP, MEASURE, MANAGE. Each contains categories and subcategories for specific actions.
Primary output	A risk-aware, iterative AI governance posture calibrated to your specific systems and operational context.
What it does NOT provide	A certifiable management system, auditable evidence requirements, or a formal policy framework.

> ***ISO 42001 is the operating system. NIST AI RMF is the diagnostic layer. One without the other is either a certificate with no real risk intelligence, or a risk methodology with no accountability structure behind it.***

SECTION 03

Structural Comparison

How the two architectures align and where they diverge

ISO 42001 Clause Structure

Clause	Title	Scope
4	**Context of the Organisation**	Scope, interested parties, AI policy context
5	**Leadership**	Top management commitment, roles, AI policy
6	**Planning**	Risk and opportunity, AI objectives, impact assessment
7	**Support**	Resources, competence, awareness, communication, documentation
8	**Operation**	Operational planning, AI system impact assessment, suppliers
9	**Performance Evaluation**	Monitoring, internal audit, management review
10	**Improvement**	Nonconformity, corrective action, continual improvement
Annex A	**38 Controls across 9 Domains**	Policies, data, training, transparency, bias, security, accountability

NIST AI RMF Function Structure

Function	Purpose
GOVERN	Establishes the policies, processes, and culture for AI risk management across the organisation.
MAP	Categorise AI systems, identify stakeholders, understand context and risk tolerance.
MEASURE	Analyse, assess, and track AI risks using qualitative and quantitative methods.
MANAGE	Prioritise and implement risk responses. Monitor residual risks. Adjust controls.

Alignment and Divergence

The two frameworks share the same intent: trustworthy, accountable AI governance. But they approach it from different directions. ISO 42001 starts with the organisation and asks what the management system looks like. NIST AI RMF starts with the AI system and asks what risks that specific system creates.

Theme	ISO 42001	NIST AI RMF	Verdict
Governance structure	Mandates formal structure	Recommends structure	ISO LEADS
Risk identification	Requires it (Clause 6)	Detailed methodology provided	NIST LEADS
Risk measurement	Minimal guidance	Core function (MEASURE)	NIST LEADS
Policy requirements	Mandatory, auditable	Guidance only	ISO LEADS
Roles and accountability	Explicit requirements	Described in GOVERN	EQUIVALENT
Operational controls	Annex A: 38 controls	MANAGE subcategories	COMPLEMENTARY
Supplier risk	Clause 8.4	MAP 3.5	COMPLEMENTARY
Monitoring and review	Clause 9	MEASURE + MANAGE	COMPLEMENTARY
Certification pathway	Yes, accredited bodies	No	ISO ONLY
Context sensitivity	Limited: generic requirements	High: operational focus	NIST LEADS

SECTION 04

Master Mapping Table

Tier 1: ISO 42001 clause-level mapping to NIST AI RMF

EQUIVALENT	Both frameworks address this with similar intent	COMPLEMENTARY	Frameworks address from different angles; both needed
ISO LEADS	ISO provides primary coverage; NIST supplements	NIST LEADS	NIST provides primary coverage; ISO states the requirement

Clause	Title	NIST Function	Subcategory	Relationship	Practitioner Note
4.1	Context of the Organisation	GOVERN	GV-1.1, GV-1.2	EQUIVALENT	Both require understanding the organisation's AI context and risk tolerance. Start here; GOVERN 1.1 extends it operationally.
4.2	Interested Parties	MAP	MP-1.5, MP-2.3	COMPLEMENTARY	ISO requires identifying interested parties. NIST adds stakeholder impact analysis including affected communities and end users.
4.3	Scope of the AIMS	GOVERN	GV-1.3	EQUIVALENT	Scope definition is required by both. ISO 42001 formalises it; NIST GOVERN 1.3 frames it around risk tolerance boundaries.
4.4	AI Management System	GOVERN	GV-1.4, GV-1.7	EQUIVALENT	The management system requirement maps directly to GOVERN's accountability structures.
5.1	Leadership and Commitment	GOVERN	GV-1.1, GV-6.1	EQUIVALENT	Top management commitment is required by both. ISO formalises it; NIST addresses it through GOVERN culture and accountability.
5.2	AI Policy	GOVERN	GV-1.1	ISO LEADS	ISO mandates a documented AI policy. NIST recommends policy but does not mandate format or audit evidence.
5.3	Roles and Responsibilities	GOVERN	GV-1.2, GV-6.2	EQUIVALENT	Both frameworks require defined roles. NIST GOVERN 6.2 extends to cross-functional AI risk ownership.
6.1	Risks and Opportunities	MAP	MP-2.0, MP-3.0	COMPLEMENTARY	ISO requires risk identification. NIST MAP provides the methodology. Use NIST to execute Clause 6.1.
6.1.2	AI Risk Assessment	MEASURE	MS-2.0, MS-2.5	COMPLEMENTARY	Primary integration point. ISO requires a risk assessment. NIST MEASURE provides the tools to perform it.
6.1.3	AI Risk Treatment	MANAGE	MG-1.0, MG-2.0	COMPLEMENTARY	ISO requires a risk treatment plan. NIST MANAGE provides the prioritisation and response framework.

Clause	Title	NIST Function	Subcategory	Relationship	Practitioner Note
6.2	AI Objectives	GOVERN	GV-1.7	EQUIVALENT	Documented objectives map to NIST's requirement for AI risk goals tied to organisational priorities.
7.1	Resources	GOVERN	GV-1.4	ISO LEADS	ISO requires formal documentation of resource allocation. NIST addresses capability without the formal assignment requirement.
7.2	Competence	GOVERN	GV-6.2	COMPLEMENTARY	ISO requires documented competence. NIST adds AI-specific skills including bias awareness and sociotechnical understanding.
7.3	Awareness	GOVERN	GV-6.1	COMPLEMENTARY	ISO mandates awareness of the AI policy. NIST adds awareness of AI risk culture across the organisation.
7.4	Communication	GOVERN	GV-1.5	EQUIVALENT	Both require communication planning for AI governance. ISO formalises internal and external requirements.
7.5	Documented Information	GOVERN	GV-1.2	ISO LEADS	ISO requires specific evidence for every significant clause. NIST recommends documentation but does not specify audit evidence requirements.
8.1	Operational Planning	MANAGE	MG-1.0	COMPLEMENTARY	ISO requires operational processes to be planned and controlled. NIST MANAGE provides the risk response framework.
8.2	AI Risk Assessment (operational)	MAP	MP-3.4, MP-5.0	COMPLEMENTARY	Operational risk assessment maps to NIST MAP's system-level categorisation and impact analysis activities.
8.3	AI System Impact Assessment	MAP	MP-2.3, MP-5.1	COMPLEMENTARY	ISO's impact assessment is best executed using NIST's stakeholder and societal harm analysis framework.
8.4	AI System Life Cycle	MAP	MP-4.0	COMPLEMENTARY	Both address life cycle management. NIST MAP 4.0 provides the contextualisation framework for each stage ISO requires to be controlled.
8.5	Supplier and Third-Party Controls	MAP	MP-3.5	COMPLEMENTARY	ISO requires third-party controls. NIST MAP 3.5 adds AI-specific supply chain risk including data provenance.
9.1	Monitoring, Measurement, Analysis	MEASURE	MS-4.0, MS-4.1	EQUIVALENT	ISO's monitoring requirement maps directly to NIST MEASURE's tracking functions, which provide the metrics methodology ISO requires.

Clause	Title	NIST Function	Subcategory	Relationship	Practitioner Note
9.2	**Internal Audit**	GOVERN	GV-1.6	ISO LEADS	Internal audit has no direct NIST equivalent. NIST GOVERN 1.6 covers review and improvement but does not mandate audit cycles.
9.3	**Management Review**	GOVERN	GV-6.2	ISO LEADS	Formal management review is an ISO requirement. NIST addresses leadership engagement but not structured periodic review.
10.1	**Nonconformity and Corrective Action**	MANAGE	MG-4.0	COMPLEMENTARY	ISO nonconformity handling maps to NIST MANAGE response functions. NIST adds AI-specific incident response and escalation protocols.
10.2	**Continual Improvement**	MANAGE	MG-4.2	COMPLEMENTARY	Both require continual improvement. NIST MANAGE 4.2 provides the feedback loop structure ISO's improvement clause requires.

SECTION 4 B

Annex A Control Mapping

Tier 2: ISO 42001 Annex A controls mapped to NIST AI RMF subcategories

Annex A contains 38 controls across 9 domains (A.2 to A.10). These are the controls an auditor verifies during certification. The A.6 AI system lifecycle domain is shown with its sub-controls listed individually for practitioner usability. Each row shows the corresponding NIST AI RMF subcategory and what implementing it provides towards ISO compliance. **Where no direct NIST subcategory exists, the closest functional equivalent is shown.** Controls labelled ISO LEADS should be addressed through ISO-specific documentation; the NIST reference provides supporting context only.

Control	Control Name	NIST Ref	Relationship	Audit Note
A.2.2	**AI Policy**	GV-1.1	EQUIVALENT	Documented policy is mandatory. NIST GOVERN 1.1 provides the risk appetite framing the policy must reflect.
A.2.3	**Internal Audit of AI Systems**	GV-1.6	ISO LEADS	No direct NIST equivalent for formal audit cycles. This ISO requirement stands alone.
A.2.4	**AI System Review**	MG-4.2	COMPLEMENTARY	NIST MANAGE 4.2 feedback loop supports the systematic review ISO requires.
A.2.5	**Supplier Relationships for AI**	MP-3.5	COMPLEMENTARY	NIST MAP 3.5 adds third-party AI risk categorisation beyond ISO's contractual controls.
A.2.6	**Responsible AI**	GV-1.1, GV-6.1	EQUIVALENT	NIST GOVERN addresses responsible AI culture; ISO formalises it as a control requirement.
A.3.2	**AI Roles and Responsibilities**	GV-1.2, GV-6.2	EQUIVALENT	Both require defined AI roles. NIST extends to cross-functional ownership including ethics review.
A.3.3	**Reporting AI Concerns**	GV-6.2	COMPLEMENTARY	NIST GOVERN 6.2 supports escalation culture; ISO requires documented reporting mechanisms.
A.4.2	**AI System Impact Assessment**	MP-2.3, MP-5.1	COMPLEMENTARY	NIST MAP provides the stakeholder and societal harm methodology ISO's impact assessment requires.
A.4.3	**Documenting AI System Objectives**	GV-1.7	EQUIVALENT	Both require documented objectives tied to organisational risk priorities.
A.4.4	**AI System Documentation**	MP-4.1	COMPLEMENTARY	ISO mandates documentation standards. NIST MAP 4.1 specifies what system documentation must capture.
A.5.2	**Data Governance**	MP-2.3	COMPLEMENTARY	ISO requires data governance controls. NIST adds data provenance, quality, and bias risk dimensions.
A.5.3	**Data Acquisition and Management**	MP-3.4	COMPLEMENTARY	NIST MAP 3.4 covers AI-specific data risks including training data bias and distribution shift.
A.5.4	**Data Quality for AI**	MS-2.5	COMPLEMENTARY	NIST MEASURE 2.5 provides measurement methods for data quality that ISO's control requires.
A.5.5	**Data Preparation**	MP-3.4	COMPLEMENTARY	Pre-processing controls in ISO map to NIST's contextualisation of data pipeline risks.

Control	Control Name	NIST Ref	Relationship	Audit Note
A.5.6	**Verification of Training Data**	MS-2.3	COMPLEMENTARY	NIST MEASURE provides testing methodologies for training data validation.
A.6.1	**AI Development Lifecycle**	MP-4.0	COMPLEMENTARY	NIST MAP 4.0 provides the context and risk framing for each stage ISO requires to be controlled.
A.6.2	**AI System Testing**	MS-2.0	COMPLEMENTARY	NIST MEASURE 2.0 provides the evaluation framework for AI system performance and risk testing.
A.6.3	**AI System Performance**	MS-4.1	EQUIVALENT	Both require performance monitoring. NIST MEASURE 4.1 adds ongoing tracking with defined metrics.
A.6.4	**Bias in AI Systems**	MS-2.5, MS-2.6	NIST LEADS	NIST provides substantially more guidance on bias identification and measurement. ISO mandates the control; NIST provides the method.
A.6.5	**Security for AI Systems**	MP-5.0	COMPLEMENTARY	ISO security controls align with NIST MAP 5.0's adversarial risk and model robustness framing.
A.6.6	**AI Incident Management**	MG-4.0	COMPLEMENTARY	NIST MANAGE 4.0 extends ISO's incident response with AI-specific escalation and containment steps.
A.6.7	**AI System Technical Documentation**	MP-4.1	COMPLEMENTARY	ISO requires documentation for all relevant stakeholder categories. NIST MAP 4.1 specifies the content and depth of system documentation.
A.6.8	**AI System Deployment**	MG-1.0	COMPLEMENTARY	ISO requires a documented deployment plan with pre-deployment criteria. NIST MANAGE 1.0 provides the operational risk framing for deployment decisions.
A.6.9	**Event Logging**	MG-3.2	COMPLEMENTARY	ISO requires event logging throughout the AI lifecycle. NIST MANAGE 3.2 adds audit trail requirements for AI decision traceability and post-incident review.
A.7.2	**Human Oversight of AI**	GV-6.1, MG-2.4	EQUIVALENT	Both require human oversight mechanisms. NIST adds specificity on human-in-the-loop and override requirements.
A.7.3	**Explainability of AI**	MS-2.6	NIST LEADS	NIST provides detailed explainability measurement guidance. ISO mandates the control but does not specify method.
A.7.4	**Transparency of AI**	GV-1.5	COMPLEMENTARY	Transparency requirements align across both. NIST extends to external stakeholder communication.
A.7.5	**AI System Robustness**	MS-2.7	NIST LEADS	NIST MEASURE 2.7 provides adversarial robustness and resilience testing guidance beyond ISO's control requirement.
A.7.6	**Data Provenance**	MP-2.3	COMPLEMENTARY	ISO requires a documented process for recording data provenance throughout the AI lifecycle. NIST MAP 2.3 provides the methodology for tracing data lineage and assessing provenance-related risk.
A.8.2	**AI Awareness**	GV-6.1	EQUIVALENT	Both require AI awareness across the organisation. NIST adds risk-culture dimensions beyond policy awareness.

Control	Control Name	NIST Ref	Relationship	Audit Note
A.8.3	**AI Training**	GV-6.2	COMPLEMENTARY	ISO requires documented training programmes. NIST GOVERN 6.2 adds competency mapping for AI risk roles.
A.8.4	**Adverse Impact Reporting**	GV-6.2	COMPLEMENTARY	ISO requires a documented process for any interested party to report adverse AI impacts. NIST GOVERN 6.2 supports escalation culture but does not mandate a formal reporting channel.
A.8.5	**Regulatory Reporting Obligations**	GV-1.5	ISO LEADS	ISO requires documented obligations for reporting information to regulators and interested parties as required by law. NIST addresses communication but does not prescribe regulatory reporting requirements.
A.9.2	**Verification of AI Outputs**	MS-4.1	COMPLEMENTARY	NIST continuous monitoring supports ISO's output verification control with measurement methodology.
A.9.3	**AI Output Logging**	MG-3.2	COMPLEMENTARY	ISO requires logging. NIST MANAGE 3.2 adds audit trail requirements for AI decision traceability.
A.9.4	**Feedback on AI System Use**	MG-4.2	EQUIVALENT	Both require feedback mechanisms from users and stakeholders to support improvement.
A.10.2	**AI Use Policies**	GV-1.1	ISO LEADS	ISO requires documented use policies. NIST addresses acceptable use within GOVERN but does not mandate format.
A.10.3	**Supplier Requirements**	MP-3.5	COMPLEMENTARY	ISO requires organisations to define and enforce AI-specific requirements for suppliers. NIST MAP 3.5 adds third-party risk categorisation and due diligence methodology beyond ISO's contractual baseline.
A.10.4	**Customer Relationships**	GV-1.5	ISO LEADS	ISO requires organisations to identify customer expectations and needs for AI systems and ensure responsible AI practices extend to customer-facing deployment. NIST addresses stakeholder communication but does not mandate customer-specific governance requirements.

SECTION 05

Reading the Interconnectivity

What each NIST function contributes to ISO 42001 implementation

The mapping table in Section 04 shows what connects to what. This section explains why those connections matter in practice. For each NIST AI RMF function: what it contributes to ISO 42001 implementation, and what you lose if you skip it.

GOVERN	ISO 42001 clauses: Clauses 4, 5, 6.2, 7, 9.2, 9.3
What it does	GOVERN establishes the conditions for AI risk management to work across the organisation. It covers accountability structures, culture, risk tolerance, policies, and workforce competency.
ISO 42001 contribution	GOVERN directly supports the ISO 42001 clauses that require formal structure: top management commitment (Clause 5), documented objectives (Clause 6.2), competence and awareness (Clauses 7.2 and 7.3), and documented information (Clause 7.5). Where ISO tells you what to have, GOVERN tells you what that structure must account for in an AI-specific context.
Without NIST AI RMF	Without GOVERN, your ISO 42001 management system may satisfy the auditor on paper but fail in practice. GOVERN forces you to address AI risk culture, cross-functional ownership, and the specific competencies required for AI governance: gaps that ISO's generic requirements do not fill on their own.

MAP	ISO 42001 clauses: Clauses 4.1, 4.2, 6.1, 8.2, 8.3, 8.4, 8.5
What it does	MAP is where you understand the context of your AI systems before you try to manage them. It covers categorisation of AI systems, identification of stakeholders and affected communities, understanding of organisational risk tolerance, and documentation of AI system purpose and impact scope.
ISO 42001 contribution	MAP is the execution engine for ISO 42001's risk and planning clauses. Clause 6.1 requires you to identify AI risks and opportunities but provides no method. MAP provides that method: categorise the system, understand who is affected, document the context, then proceed to risk assessment. Clause 8.3's impact assessment is fulfilled substantially through MAP's stakeholder and societal harm analysis.
Without NIST AI RMF	Without MAP, ISO 42001 risk assessments tend to be generic. Organisations list risks by category rather than by the specific operational context of each AI system. An auditor may accept this. A regulator examining an AI harm incident will not. MAP is what makes your risk identification defensible.

MEASURE	ISO 42001 clauses: Clauses 6.1.2, 9.1 and Annex A: A.6.2, A.6.3, A.6.4, A.7.3, A.7.5
What it does	MEASURE provides the analytical tools for AI risk quantification and tracking. It covers risk analysis methods, bias evaluation, explainability measurement, robustness testing, and ongoing performance monitoring. It answers the question ISO 42001 asks but does not answer: how do you actually measure AI risk?
ISO 42001 contribution	ISO 42001 Clause 6.1.2 requires an AI risk assessment. Clause 9.1 requires monitoring and measurement. Neither tells you how. MEASURE provides the framework: define metrics, select evaluation approaches, measure against defined thresholds, track over time. For Annex A controls on bias (A.6.4), explainability (A.7.3), and robustness (A.7.5), MEASURE is the methodology behind the control.
Without NIST AI RMF	Without MEASURE, ISO 42001 monitoring and measurement becomes a compliance activity rather than a risk management activity. You will have a monitoring register. You may not have meaningful metrics. MEASURE is what converts your management system from a documentation exercise into a system that actually detects AI risk before it becomes an incident.

MANAGE	ISO 42001 clauses: Clauses 6.1.3, 8.1, 10.1, 10.2 and Annex A: A.6.5, A.6.6
What it does	MANAGE covers the response side: prioritising risks, implementing treatments, responding to incidents, and driving continual improvement. It provides the operational risk response framework that ISO 42001's treatment and improvement clauses require.
ISO 42001 contribution	ISO 42001 Clause 6.1.3 requires a risk treatment plan. Clause 10.1 requires nonconformity handling and corrective action. MANAGE provides the prioritisation logic and response sequencing these clauses need. MANAGE 4.0's incident response framework directly supports Annex A control A.6.6, adding AI-specific escalation and containment steps beyond ISO's generic corrective action.
Without NIST AI RMF	Without MANAGE, ISO 42001 treatment plans default to generic control categories. MANAGE forces specificity: which risks are prioritised, what the treatment rationale is, how residual risk is tracked, and what triggers a review. For organisations operating high-risk AI systems, this specificity is not optional.

SECTION 06

Implementation Playbook

How to sequence ISO 42001 and NIST AI RMF without duplicating effort

The most common mistake is treating these as sequential projects: implement ISO 42001, then layer in NIST AI RMF. That approach doubles the work and produces a management system that sits above the risk intelligence rather than being shaped by it. Run them in parallel from the start.

> ***ISO 42001 is the spine. NIST AI RMF is the diagnostic layer that runs alongside it. Build the structure and the risk intelligence together. They are designed to reinforce each other.***

Phase 1 **Foundation**	Weeks 1 to 6
ISO 42001 WORK	**NIST AI RMF WORK**
• Clause 4: Define scope. Document context, interested parties, and AI policy. • Clause 5: Secure top management commitment. Assign AI governance roles formally. • Clause 6.2: Set AI objectives tied to your risk appetite.	• GOVERN: Establish risk tolerance. Identify who owns AI risk decisions. • MAP 1.0: Inventory your AI systems. Categorise by risk tier. • MAP 2.0: Identify stakeholders and affected communities for each system.
INTEGRATION POINT	Clause 4.1 context-setting and GOVERN 1.1 risk tolerance framing happen simultaneously. The output of GOVERN feeds directly into your ISO scope document.

Phase 2	**Build**	Weeks 7 to 18

ISO 42001 WORK	NIST AI RMF WORK
• Clause 6.1: Conduct your AI risk assessment. Document risks and treatment plans. • Clause 7: Build your competence framework, awareness programme, and documentation controls. • Clause 8: Implement operational controls. Run impact assessments. Address supplier risks. • Annex A: Implement applicable controls. Document evidence for each.	• MAP 3.0 to 5.0: Complete system-level risk categorisation, data risk, and impact analysis. • MEASURE 2.0: Execute AI risk analysis: bias testing, performance evaluation, robustness checks. • MANAGE 1.0 to 2.0: Prioritise risks. Document treatment rationale. Assign response owners.

INTEGRATION POINT	Clause 6.1.2 risk assessment is executed using NIST MEASURE methodology. Annex A controls on bias, explainability, and security use NIST as the technical method behind the ISO control.

Phase 3	**Audit-Ready**	Weeks 19 to 24

ISO 42001 WORK	NIST AI RMF WORK
• Clause 9.1: Implement monitoring. Define KPIs for your AI management system. • Clause 9.2: Conduct internal audit against all clauses and Annex A controls. • Clause 9.3: Hold management review. Document outputs and decisions. • Clause 10: Address nonconformities. Document corrective actions.	• MEASURE 4.0: Deploy continuous monitoring. Track risk metrics against thresholds. • MANAGE 4.0: Operationalise incident response. Test escalation paths. • MANAGE 4.2: Establish feedback loops from operations back into risk assessment.

INTEGRATION POINT	NIST continuous monitoring (MEASURE 4.0) provides the data that ISO Clause 9.1 requires. Your management review (Clause 9.3) should incorporate NIST risk tracking outputs directly.

SECTION 07

The Gap Register

What each framework requires that the other does not cover

The most dangerous assumption in dual-framework implementation is that satisfying one framework gives coverage for the other. It does not. This register documents the genuine gaps in both directions.

What ISO 42001 Requires That NIST AI RMF Does Not Cover

These requirements must be fulfilled for ISO 42001 certification. Implementing NIST alone does not satisfy them.

ISO 42001 Requirement	Clause	Gap Detail	Action Required
Certified management system	**4.4**	NIST has no certification pathway or accreditation body.	Engage an ISO-accredited certification body. NIST alignment does not substitute.
Documented AI Policy	**5.2 / A.2.2**	NIST recommends policy but does not mandate a documented, auditable artefact.	Draft and approve a formal AI Policy with version control and sign-off records.
Internal Audit programme	**9.2 / A.2.3**	No equivalent audit cycle requirement exists in NIST AI RMF.	Establish a scheduled internal audit programme with documented findings and corrective actions.
Management Review	**9.3**	NIST addresses senior leadership but not formal periodic review with documented outputs.	Hold structured management reviews. Document agenda, attendees, decisions, and follow-up actions.
Nonconformity handling	**10.1**	NIST addresses improvement but not the formal nonconformity and corrective action process.	Implement a nonconformity register with root cause analysis and corrective action tracking.
Resource allocation records	**7.1**	NIST addresses capability but not formal documented resource assignment.	Document resource allocation decisions for the AIMS. Link to budget and headcount records.
Documented information controls	**7.5**	ISO requires specific audit evidence for every significant clause. NIST does not.	Build a document register. Assign owners, review cycles, and version history to all AIMS documentation.

What NIST AI RMF Covers That ISO 42001 Leaves Open

ISO-certified organisations without NIST alignment are likely to have these as implementation weaknesses: ISO requires them but without NIST they remain unresolved.

NIST AI RMF Capability	Function	Gap Detail	Action Required
AI system categorisation methodology	**MAP 1.0**	ISO requires scope definition but provides no system classification method.	Use NIST MAP 1.0 to categorise AI systems by risk tier. Feed outputs into ISO Clause 4.3.
Stakeholder and societal harm analysis	**MAP 2.3**	ISO requires impact assessment (Clause 8.3) but provides no stakeholder harm methodology.	Apply NIST MAP stakeholder analysis to each AI system. Document affected communities.
Bias identification and measurement	**MS-2.5, 2.6**	ISO Annex A requires bias controls (A.6.4) but no measurement guidance.	Use NIST MEASURE 2.5/2.6 for bias testing. Document metrics, thresholds, and test results.
Explainability measurement	**MS-2.6**	ISO requires explainability (A.7.3) as a control but provides no method.	Define explainability requirements per system using NIST guidance. Document evaluation approach and outcomes.
Adversarial robustness testing	**MS-2.7**	ISO requires robustness (A.7.5) but provides no testing methodology.	Apply NIST adversarial robustness evaluation. Document attack surface analysis and test results.
Continuous AI risk monitoring	**MEASURE 4.0**	ISO Clause 9.1 requires monitoring but specifies no AI-specific metrics or methods.	Implement NIST-informed monitoring metrics per AI system. Define thresholds, owners, and cadence.
Third-party AI data provenance	**MAP 3.5**	ISO Clause 8.5 covers supplier controls but not AI-specific supply chain risk.	Assess data and model provenance for all third-party AI inputs using NIST MAP 3.5.
Iterative risk re-assessment	**MANAGE 4.2**	ISO requires continual improvement (Clause 10.2) but not the iterative feedback loop mechanism.	Establish NIST-informed feedback cycles from operations into risk register updates.

SECTION 08

Quick Reference Card

Key mappings, terms, and decision guidance

Key Terms Side by Side

ISO 42001 Term	Definition	NIST AI RMF Term	Definition
AIMS	AI Management System: the formal, documented management system ISO 42001 requires you to build, maintain, and have certified.	**AI Risk Profile**	A documented, organisation-specific characterisation of AI risks across all AI systems and their operational contexts.
Clause	A numbered requirement section in ISO 42001 (Clauses 4 to 10). Every clause requires documented evidence for certification.	**Function**	One of NIST's four core activity categories: GOVERN, MAP, MEASURE, MANAGE. Each contains categories and subcategories.
Annex A Control	One of 38 specific controls in ISO 42001's normative annex. These are what an external auditor directly verifies during certification.	**Subcategory**	A specific, measurable outcome within a NIST function (e.g. GV-1.1). The most granular and actionable level of the framework.
Scope	The defined boundary of the AIMS: which AI systems, processes, and organisational units are covered by the management system.	**AI Risk Tolerance**	The level of AI-related risk an organisation is willing to accept. NIST GOVERN requires this to be explicitly defined and documented.
Nonconformity	A failure to meet an ISO 42001 requirement. Must be documented, root-cause analysed, and corrected with evidence of resolution.	**AI Trustworthiness**	NIST's term for the properties that define a responsible AI system: accuracy, reliability, fairness, explainability, and resilience.
Corrective Action	The formal response to a nonconformity. ISO requires documented root cause analysis, the action taken, and evidence of effectiveness.	**AI Incident**	Any event where an AI system causes or contributes to harm, failure, or unexpected behaviour. NIST MANAGE defines response protocols.

ISO 42001 Term	Definition	NIST AI RMF Term	Definition
Management Review	A periodic, structured review of the AIMS by top management. Required by Clause 9.3. Outputs must be documented decisions and actions.	**Continuous Monitoring**	The ongoing tracking of AI system performance and risk against defined metrics. NIST MEASURE 4.0 provides the framework for this activity.
Certifiable	ISO 42001 supports third-party certification by an accredited certification body, providing independent external verification and commercial proof.	**Resilient**	NIST AI RMF builds operational resilience: the ability to identify, respond to, and recover from AI risks in practice, not just on paper.
Interested Party	Any person or organisation that can affect, be affected by, or perceive themselves to be affected by the organisation's AI systems. Required in Clause 4.2.	**Affected Community**	NIST's term for individuals or groups who may experience harm from an AI system, even if they are not direct users or customers.

Five Critical Mapping Relationships

These five pairings are where the two frameworks do their most important joint work. If you implement only one, these are the gaps you carry.

#	Mapping Relationship	Why This Pairing Matters
1	**ISO Clause 6.1.2 + NIST MEASURE 2.0**	The primary integration point. ISO requires a risk assessment. NIST provides the method. You cannot do one properly without the other. This is where the management system and the risk methodology become one.
2	**ISO Clause 8.3 + NIST MAP 2.3**	ISO's AI system impact assessment is best executed using NIST's stakeholder and societal harm analysis. MAP gives the methodology that ISO's clause assumes you already have. Without it, impact assessments are theoretical.
3	**ISO Annex A.6.4 + NIST MS-2.5/2.6**	ISO requires bias controls. NIST provides the measurement framework. Without NIST, bias controls in an ISO audit are policy assertions without evidence. With it, you have documented metrics and test results.
4	**ISO Clause 9.1 + NIST MEASURE 4.0**	ISO requires monitoring and measurement. NIST defines what AI monitoring looks like in practice: specific metrics, thresholds, tracking cadence, and escalation triggers. ISO tells you to monitor. NIST tells you how.
5	**ISO Clause 10.2 + NIST MANAGE 4.2**	ISO requires continual improvement. NIST's feedback loop mechanism is what makes improvement systematic rather than reactive. MANAGE 4.2 creates the operational cycle that feeds real data back into your AIMS.

Decision Guide: Where to Start

Primary driver is certification	Start with ISO 42001 Clauses 4 and 5. Build your scope and policy first. Then run NIST MAP alongside Clause 6.1 to ensure your risk assessment has operational depth. Certification is your end state; NIST is what makes it defensible.
Primary driver is US regulatory or customer alignment	Start with NIST GOVERN and MAP. Establish your risk tolerance and system categorisation. Then align your NIST outputs to ISO 42001 clauses to build the management system structure around your risk intelligence. NIST is your starting point; ISO gives it accountability structure.
Primary driver is both simultaneously	Run Phase 1 of the Implementation Playbook in Section 06 as your starting point. Clauses 4 to 5 and GOVERN happen in parallel. Risk assessment (Clause 6.1) and NIST MAP happen together. This is the highest-effort path and the highest-quality outcome.

> ***ISO 42001 without NIST AI RMF is a certificate without operational depth. NIST AI RMF without ISO 42001 is risk intelligence without accountability structure. Together, they build something neither can deliver alone: a system that is certifiable and resilient.***